

Lecture 5:

Network Security

Eleftheria Makri | Security

11/03/2026



Universiteit
Leiden

Bij ons leer je de wereld kennen

Network Security

- Interesting Secure ***Protocols*** and ***Attacks*** per OSI Layer
 - IPSec
 - ICMP Redirect Attack
 - Smurf (and Fraggle) Attack
 - TCP Three Way Handshake and SYN Flooding
 - SSH
 - HTTPS
 - DNS Spoofing and DNS Poisoning
- Firewalls
 - Packet-filtering Firewalls
 - Proxy Firewalls
 - Tiered Architecture
- Intrusion Detection Systems
 - Event Analysis Methods
 - Base Rate Fallacy

Interesting Secure *Protocols* and *Attacks* per OSI Layer



7 Layers of the OSI Model

Application

- End User layer
- HTTP, FTP, IRC, SSH, DNS

Presentation

- Syntax layer
- SSL, SSH, IMAP, FTP, MPEG, JPEG

Session

- Synch & send to port
- API's, Sockets, WinSock

Transport

- End-to-end connections
- TCP, UDP

Network

- Packets
- IP, ICMP, IPsec, IGMP

Data Link

- Frames
- Ethernet, PPP, Switch, Bridge

Physical

- Physical structure
- Coax, Fiber, Wireless, Hubs, Repeaters

7 Layers of the OSI Model

Application

- End User layer
- HTTP, FTP, IRC, SSH, DNS

Presentation

- Syntax layer
- SSL, SSH, IMAP, FTP, MPEG, JPEG

Session

- Synch & send to port
- API's, Sockets, WinSock

Transport

- End-to-end connections
- TCP, UDP

Network

- Packets
- IP, ICMP, IPSec, IGMP

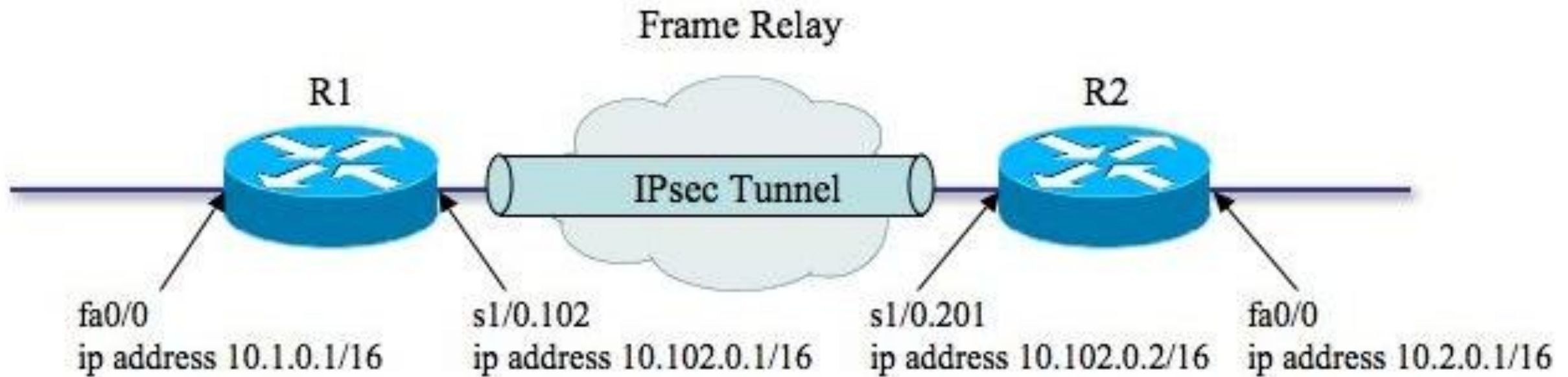
Data Link

- Frames
- Ethernet, PPP, Switch, Bridge

Physical

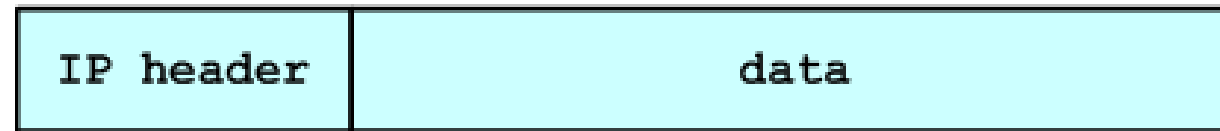
- Physical structure
- Coax, Fiber, Wireless, Hubs, Repeaters

IPSec



Authentication Header

original IP packet



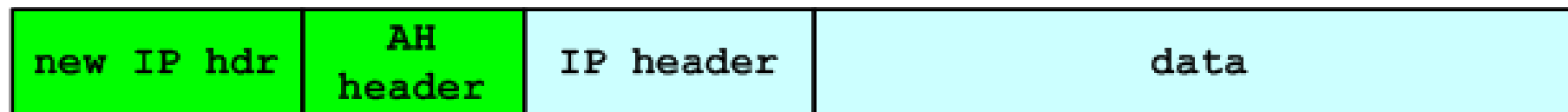
AH

transport mode



← authenticated except mutable fields →

tunnel mode



← authenticated except mutable fields →

Encapsulating Security Payload

ESP

transport mode



tunnel mode



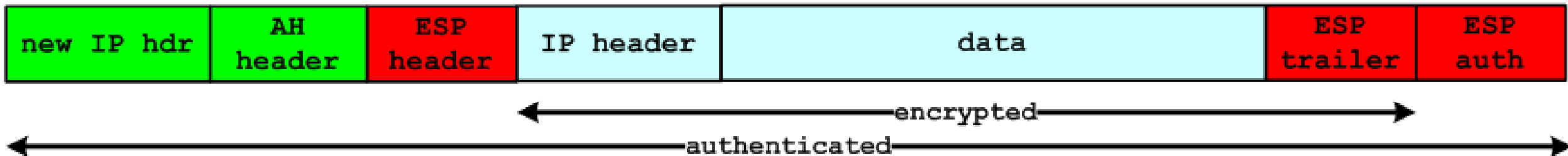
(Rarely) combining ESP and AH

AH & ESP

transport mode



tunnel mode



Putting it all together



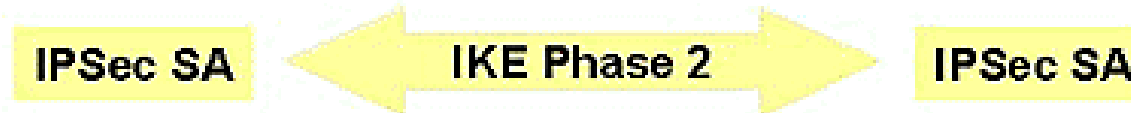
Internet Key Exchange (IKE)



1. Host A sends interesting traffic to Host B.
2. Router A and B negotiate an IKE phase one session.



3. Router A and B negotiate an IKE phase two session.

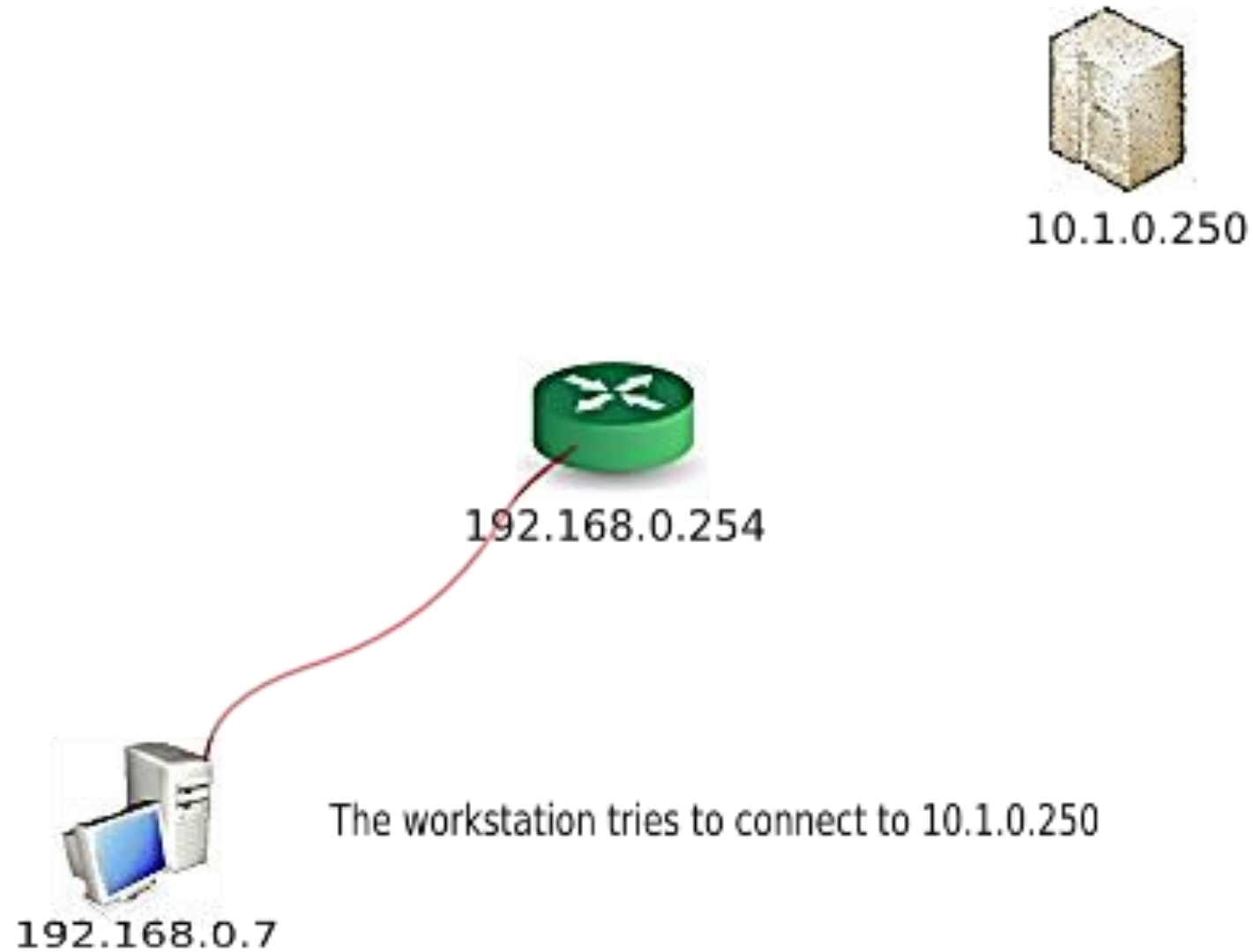


4. Information is exchanged via IPSec tunnel.



5. IPSec tunnel is terminated.

Internet Control Message Protocol

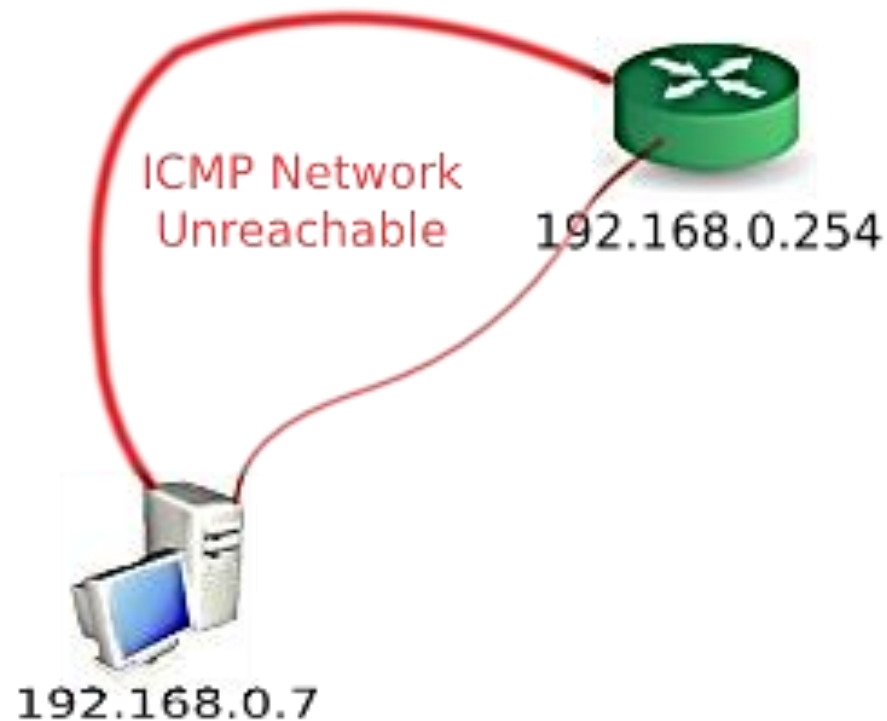


Internet Control Message Protocol

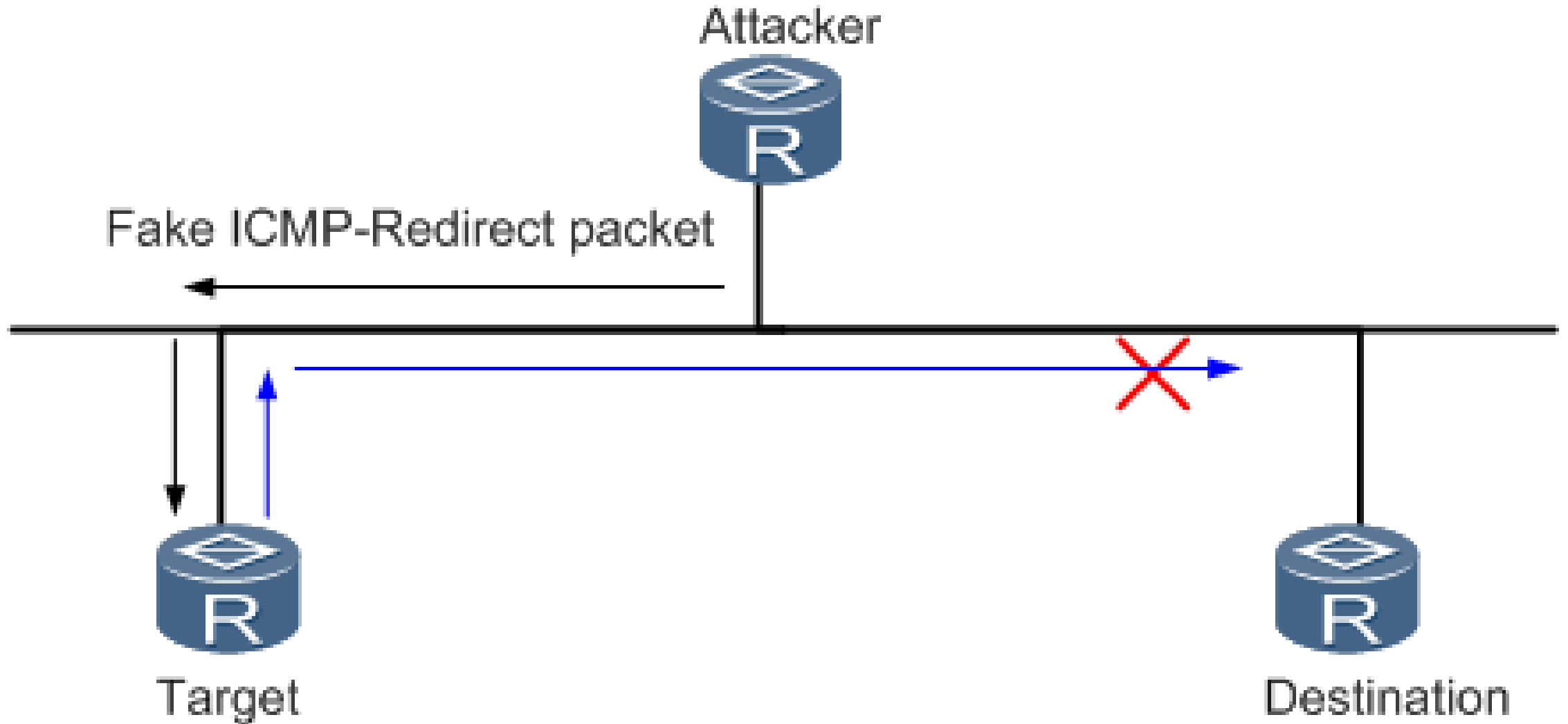
The router sends back an ICMP error message "Network Unreachable to 10.1.0.250"



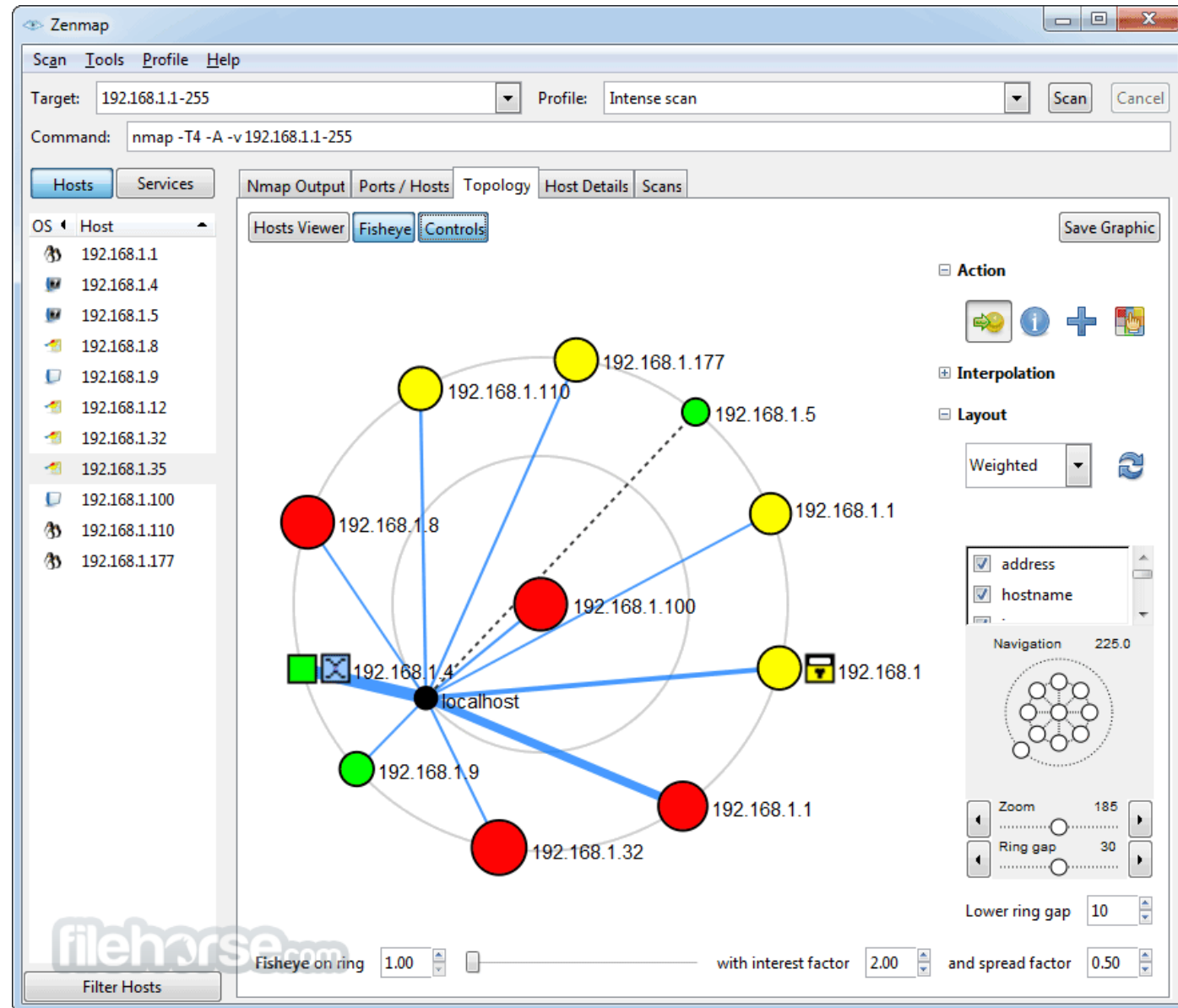
10.1.0.250



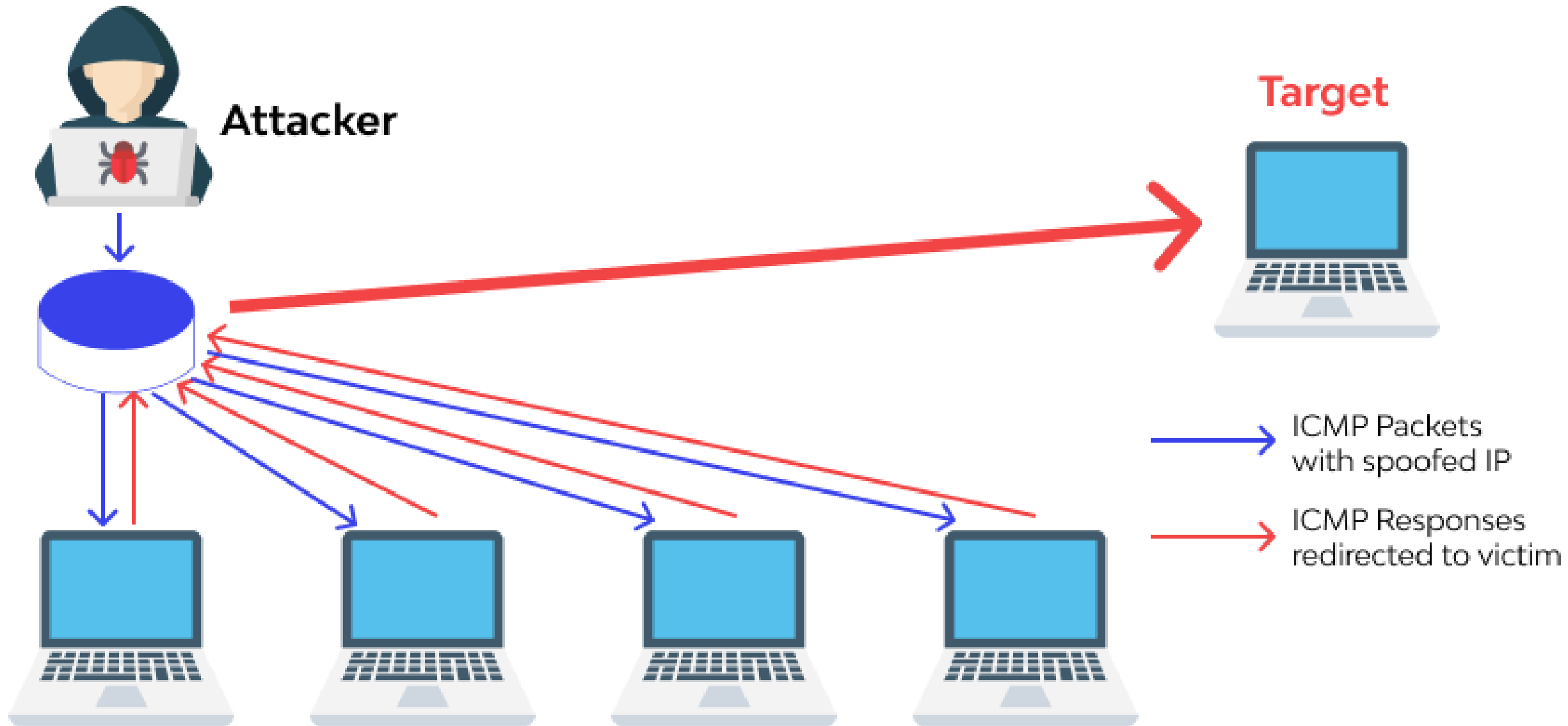
ICMP Redirect Attack



Ping Scanning – The gray zone



Smurf Attack



7 Layers of the OSI Model

Application

- End User layer
- HTTP, FTP, IRC, SSH, DNS

Presentation

- Syntax layer
- SSL, SSH, IMAP, FTP, MPEG, JPEG

Session

- Synch & send to port
- API's, Sockets, WinSock

Transport

- End-to-end connections
- TCP, UDP

Network

- Packets
- IP, ICMP, IPSec, IGMP

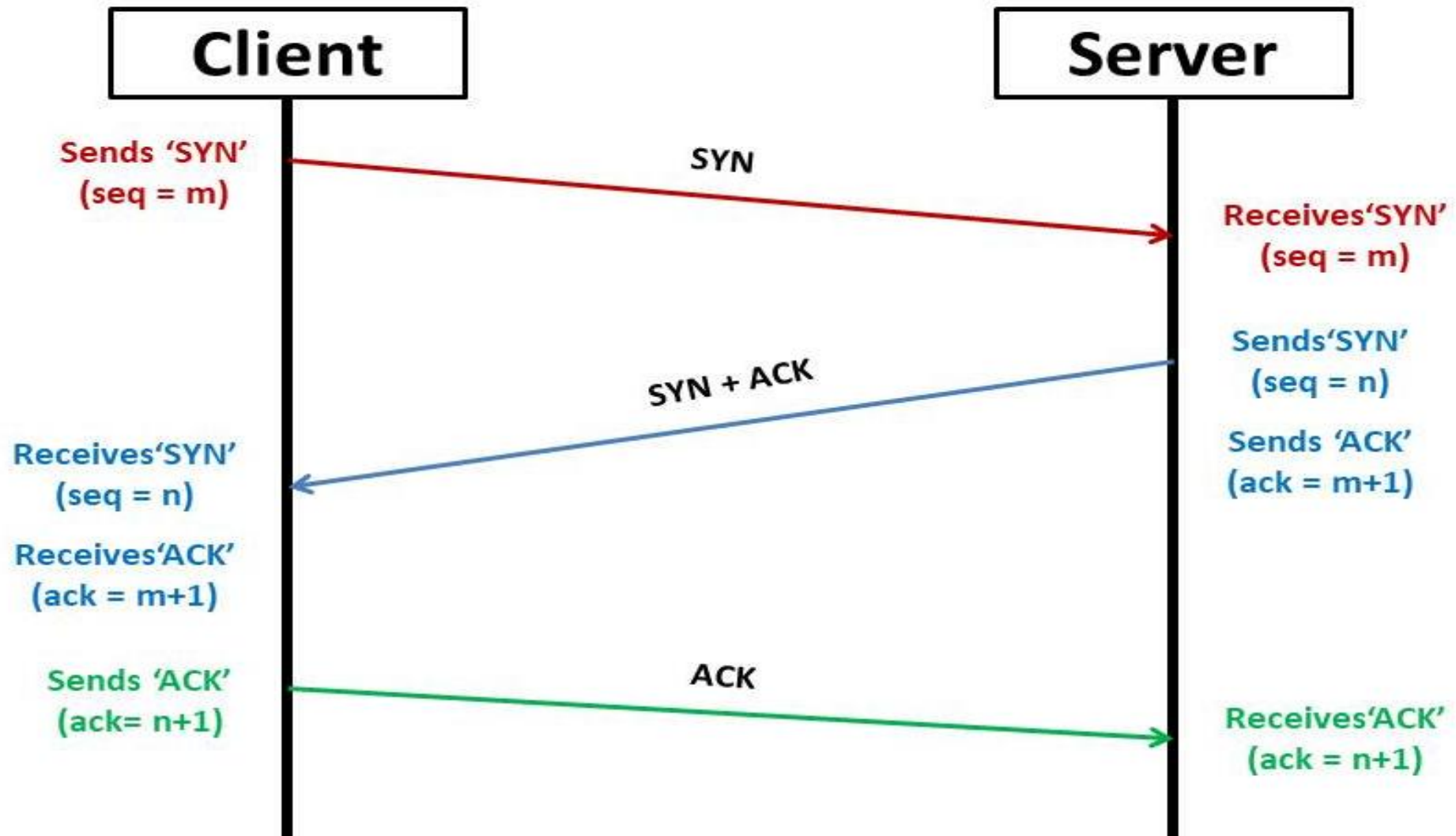
Data Link

- Frames
- Ethernet, PPP, Switch, Bridge

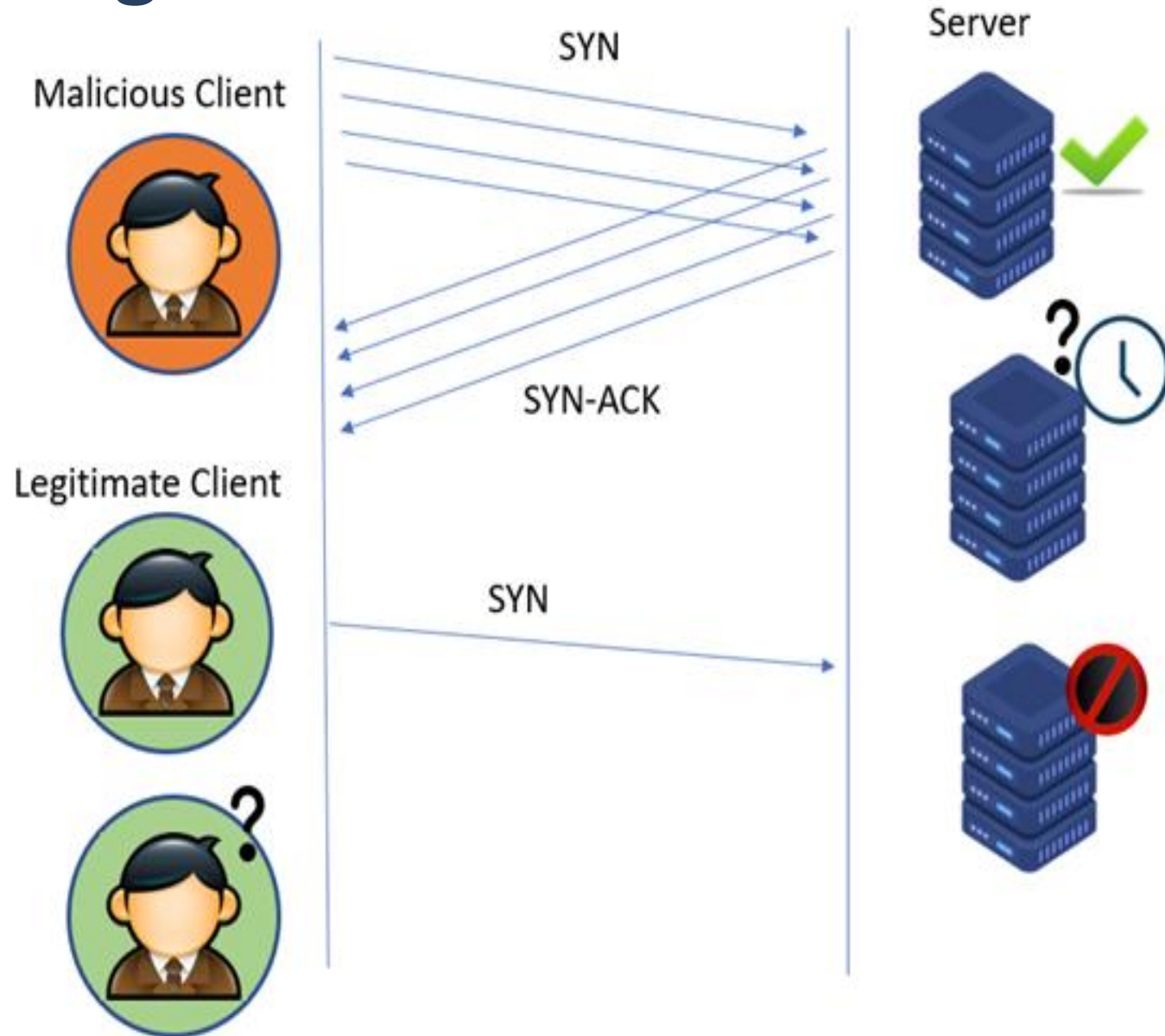
Physical

- Physical structure
- Coax, Fiber, Wireless, Hubs, Repeaters

TCP Three Way Handshake



SYN Flooding Attack



7 Layers of the OSI Model

Application

- End User layer
- HTTP, FTP, IRC, SSH, DNS

Presentation

- Syntax layer
- SSL, SSH, IMAP, FTP, MPEG, JPEG

Session

- Synch & send to port
- API's, Sockets, WinSock

Transport

- End-to-end connections
- TCP, UDP

Network

- Packets
- IP, ICMP, IPSec, IGMP

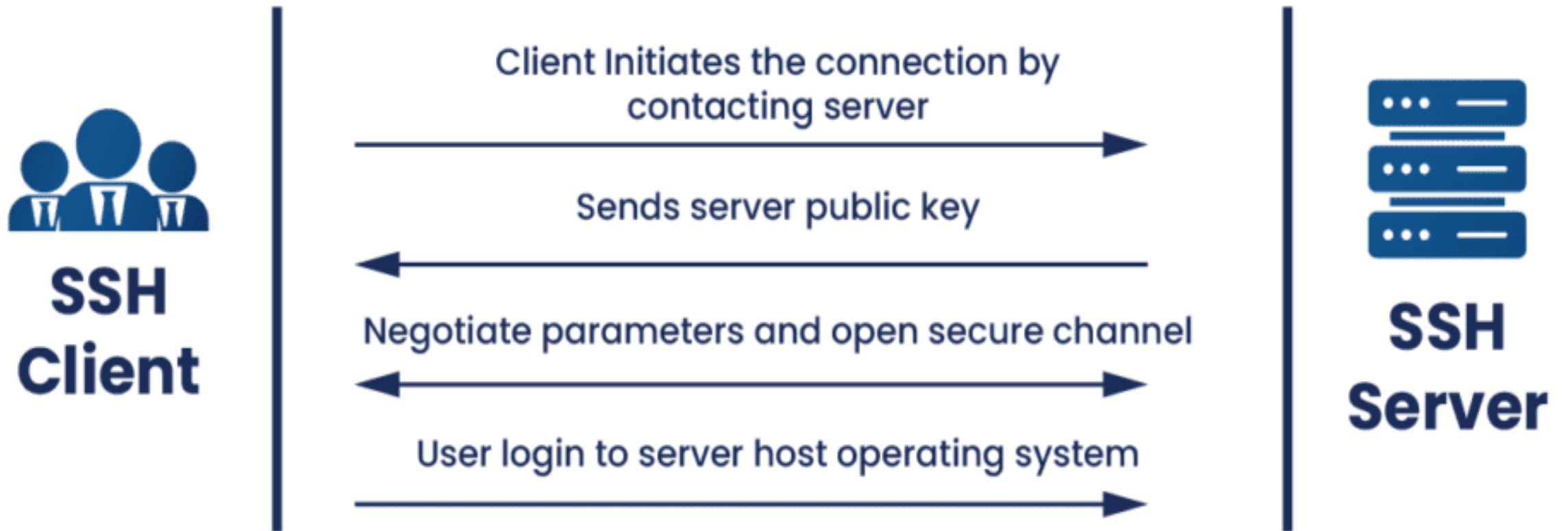
Data Link

- Frames
- Ethernet, PPP, Switch, Bridge

Physical

- Physical structure
- Coax, Fiber, Wireless, Hubs, Repeaters

SSH – Secure Shell



7 Layers of the OSI Model

Application

- End User layer
- HTTP, FTP, IRC, SSH, DNS

Presentation

- Syntax layer
- SSL, SSH, IMAP, FTP, MPEG, JPEG

Session

- Synch & send to port
- API's, Sockets, WinSock

Transport

- End-to-end connections
- TCP, UDP

Network

- Packets
- IP, ICMP, IPSec, IGMP

Data Link

- Frames
- Ethernet, PPP, Switch, Bridge

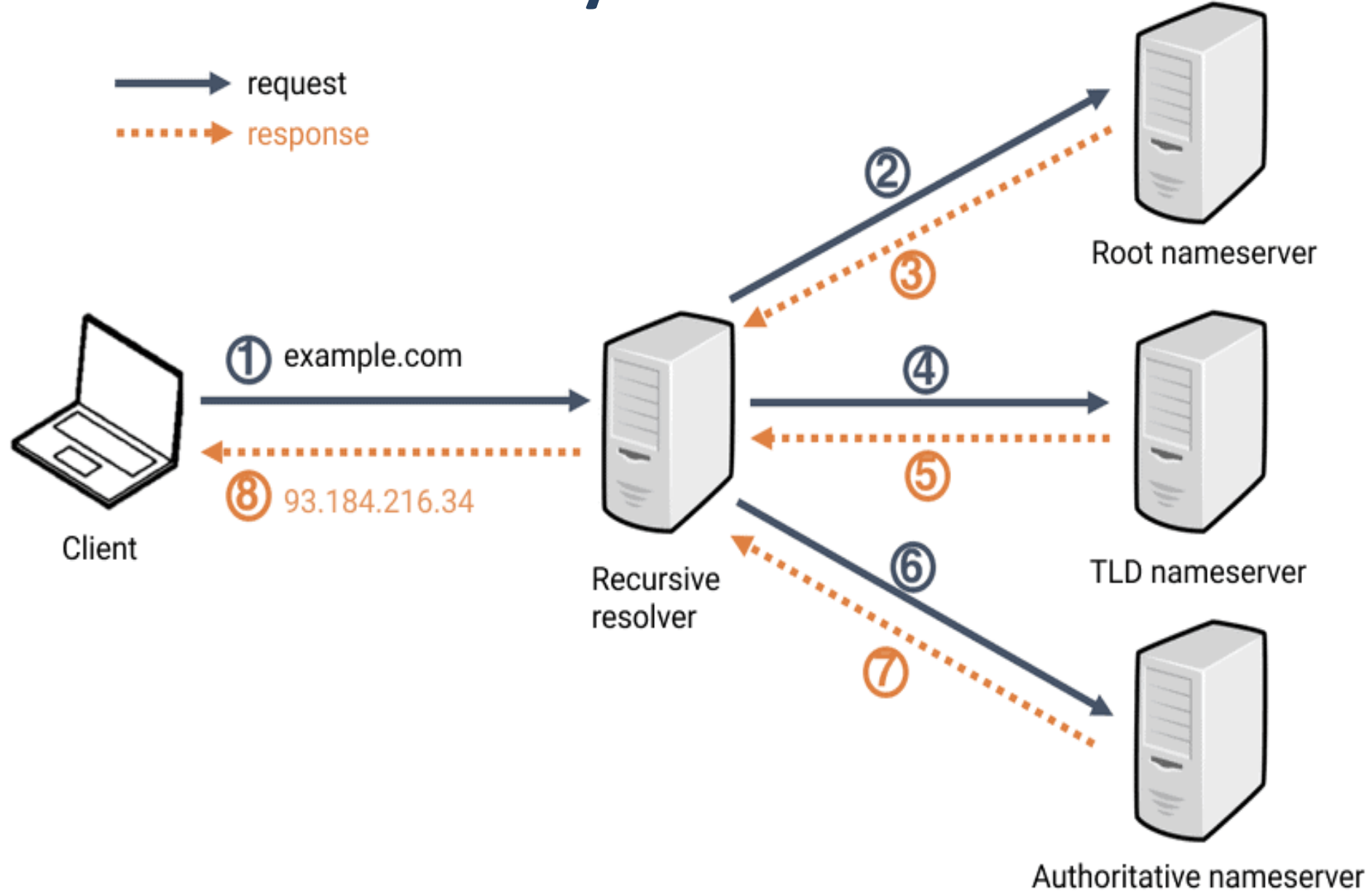
Physical

- Physical structure
- Coax, Fiber, Wireless, Hubs, Repeaters

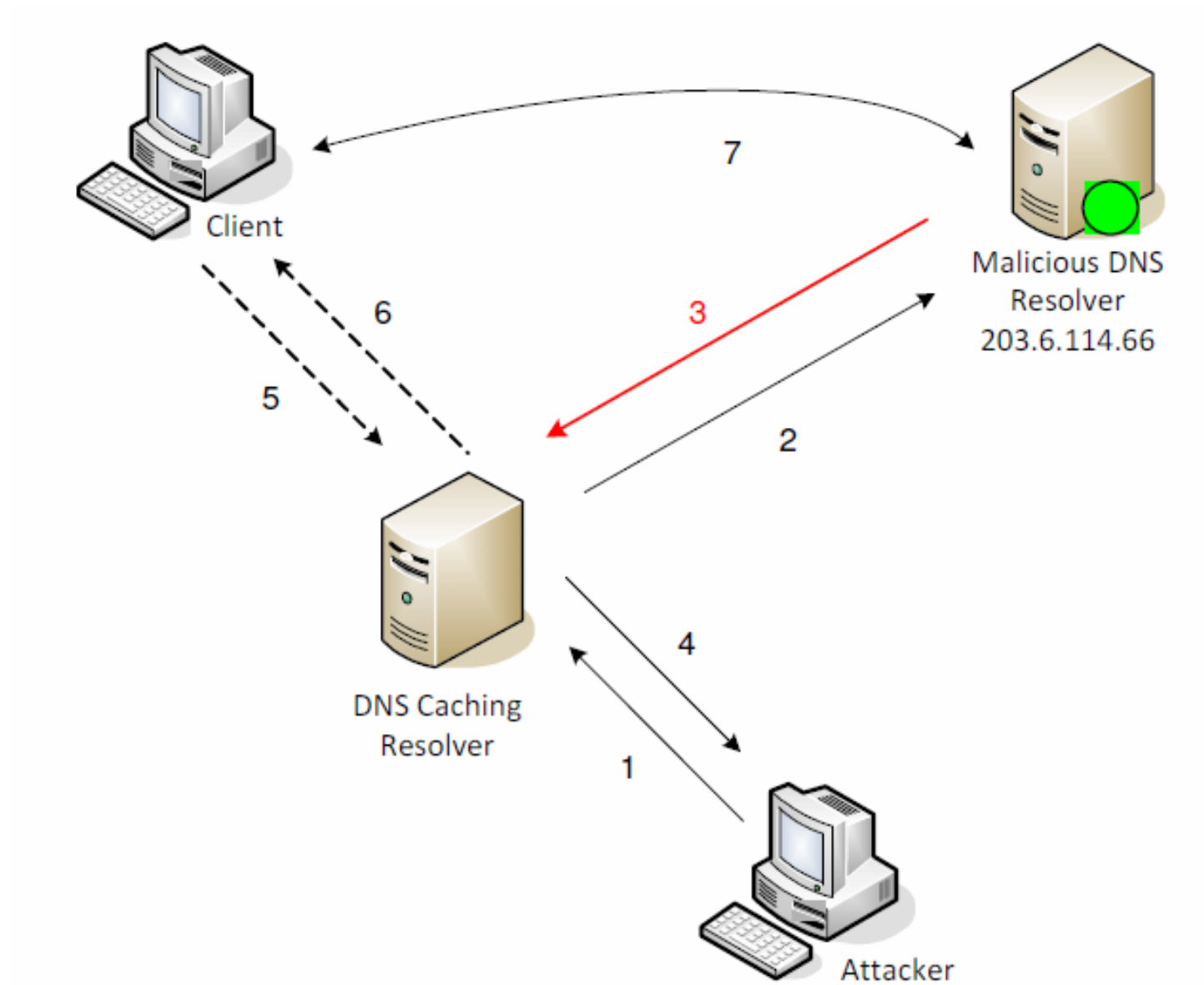


<https://www>

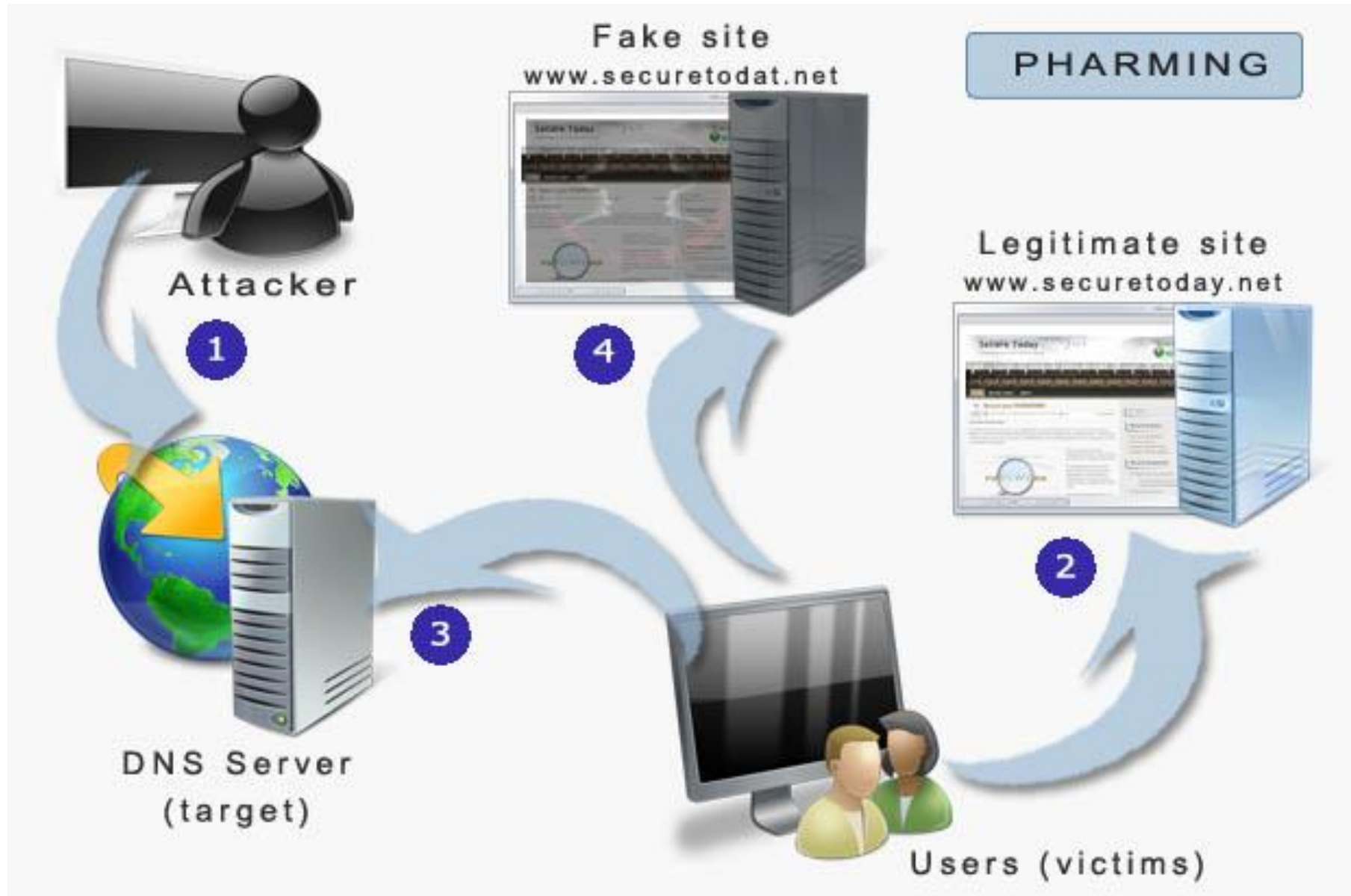
The Domain Name System – DNS



DNS Spoofing and DNS Poisoning

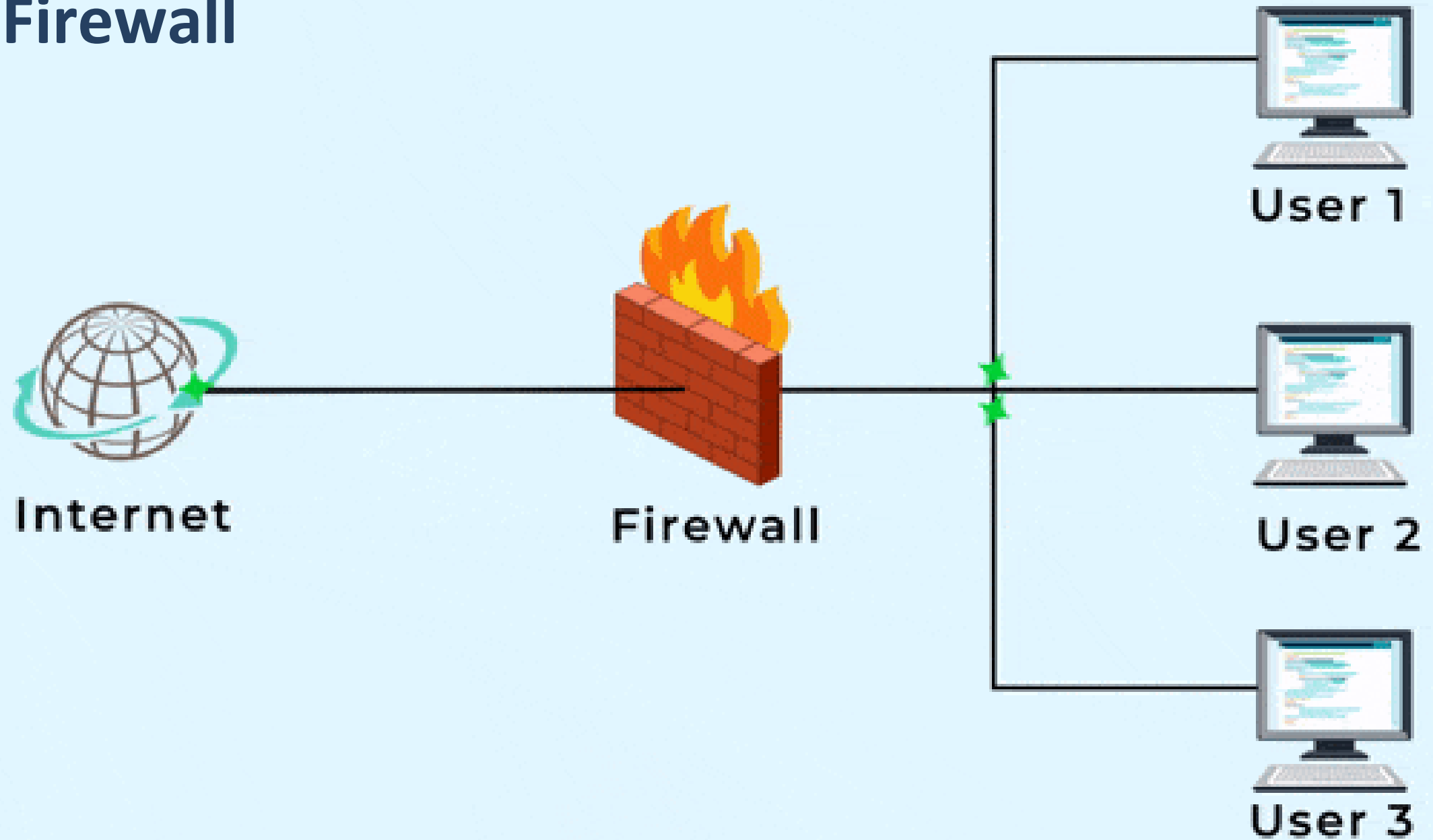


And another way of Pharming (attack)



Firewalls

Firewall



Packet-filtering Firewalls

- Most common kind of firewalls
 - Linux: iptables and nftables. Windows: Microsoft Defender Firewall
 - Usually active by default
- Behave based on list of rules matching packets
 - IF packet matches THEN action
 - Action: ACCEPT, REJECT, DROP

Advantages and Disadvantages of Packet-filtering Firewalls

- + Powerful protection for entire network: filtered packets never reach devices
 - + Significantly reduce attack surface
- + Simple rule matching → very efficient
- + Widely available, many resources: documentation, GUIs, . . .
- Usability: firewall cannot block everything
 - Possible to hide traffic as different protocol/port
- Bugs in rules
- Need to balance protection and rule complexity
 - e.g., whitelisting every single authorized IP
- Only works if traffic transits through firewall
 - e.g., using mobile data instead of WiFi
- + Overall, widely deployed, especially for large networks

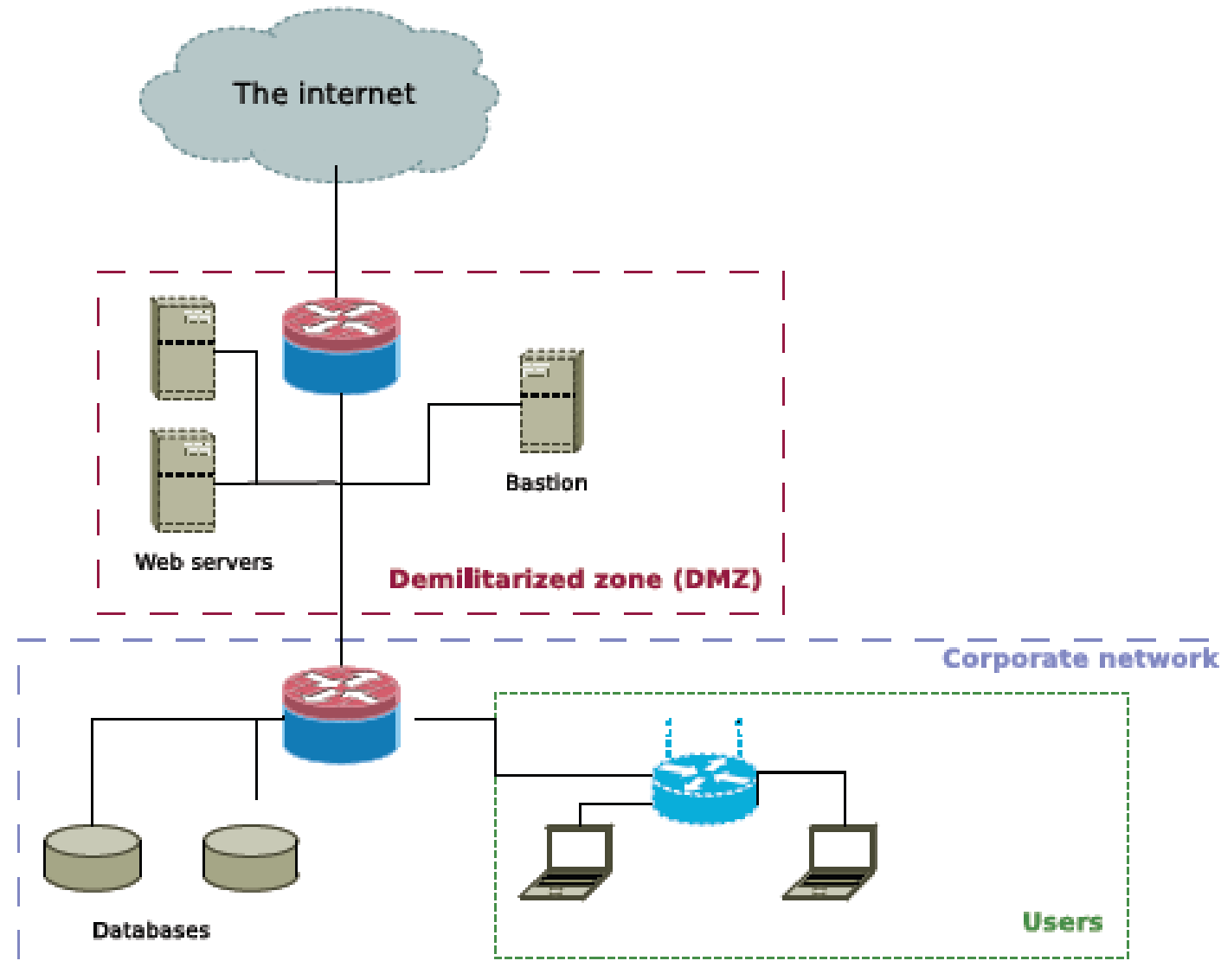
Proxy Firewall

- Application-level (OSI layer 7)
- (Forced) intermediary between A and B:
 1. Proxy receives request from A
 2. Proxy makes similar request to B
 3. Proxy receives response from B
 4. Proxy crafts and send response to A
- Can be explicit or transparent
 - Transparent: one of the devices does not know proxy is in place
- Can require authentication

Advantages and Disadvantages of Proxy Firewalls

- Application knowledge
 - + Logging → accountability
 - + Caching → bandwidth reduction
 - + More intelligent filtering
 - Application-specific
- + Aggregation of clients under same endpoint → anonymity
- Complex: can degrade performances
- Usually requires specific setup for one end of connection
- + Allows controlled connections to a service without service needing to implement authentication (e.g., SOCKS proxy)
- Need to trust proxy with handling sensitive data
 - Basically, an authorized man-in-the-middle attack

Tiered Networks



Intrusion Detection Systems

IDS vs. I(D)PS

- Intrusion detection is the process of ***monitoring*** and ***analyzing*** system events to ***identify*** and ***report*** attempts to access resources in an unauthorized manner.
- Intrusion prevention systems additionally ***take action*** in response to detected (unauthorized) activity to ***stop*** or ***contain*** the activity.
- Actions include:
 - Alter packets (e.g., strip malware)
 - Sandbox users/connections
 - Shut down connections, processes, systems
 - Redirect to honeypots

Event Sources for Intrusion Detection

- NIDS: Network-based IDS
 - Events derived from listeners at strategic points
 - Router, gateways, switches
 - Use packet sniffing to observe in-transit packets
 - Snort, Suricata
- HIDS: Host-based IDS
 - Events derived from kernel operations, application logs, filesystem changes,
 - system calls, host network accesses . . .
 - OSSEC

Signature-Based Event Analysis

- Define signatures, i.e., malicious patterns
 - Condition lists, e.g., fields in packet headers
 - Raw byte sequences
- Match events against signatures
- alert icmp \$EXTERNAL_NET any -> \$HOME_NET any (dsize: 0; itype: 8; msg: "ICMP PING NMAP");
- nmap scans a network by sending empty ICMP "ping" packets and seeing which hosts responds → obtains network topology
- Rule detects such packets and can warn about initial step of an attack

Advantages and Disadvantages of Signature-Based IDS

- + Fast
- + Accurate
- + Signatures can be shared: learn from others
- Signatures need to be updated by somebody
- Malicious actors try to obfuscate their signatures

Anomaly-Based Event Analysis

- Build profiles of legitimate users
- Identify deviations from these profiles
- Examples:
 - Number of (failed) login attempts
 - Number of accesses/deleted files (within a time window)
 - Commands executed
 - Resources consumed (e.g., CPUs)

Advantages and Disadvantages of Anomaly-Based IDS

- + Detects “never seen before” attacks
- + “Automatic” learning
- Difficult to configure
 - Selecting features
 - Ensure intruder-free training
 - Usual problems of training a ML/anomaly detection model → tradeoffs
- Legitimate users can behave abnormally → false positives

Base Rate Fallacy

- We can adjust the sensitivity of IDSs (usually) both during training and during operation
 - Can be made more sensitive → better detection but false positives
 - Can be made less sensitive → might miss some malicious activity

Predicted	Actual	
	Positive	Negative
Positive	True positive (predicted positive Actual positive)	False positive (predicted positive Actual negative)
Negative	False negative (predicted negative Actual positive)	True negative (predicted negative Actual negative)

Base Rate Fallacy – Example

- Suppose your doctor performs a test that is 99% accurate
 - When performed on 100 sick subjects, 99 flagged as positive
 - When performed on 100 healthy subjects, 99 flagged as negative
- You tested positive

Should you be worried?

Base Rate Fallacy – Example

- Suppose your doctor performs a test that is 99% accurate
 - When performed on 100 sick subjects, 99 flagged as positive
 - When performed on 100 healthy subjects, 99 flagged as negative
- You tested positive

Should you be worried?

It depends on the disease's ***rate of incidence***

Base Rate Fallacy – Example

- Suppose your doctor performs a test that is 99% accurate
 - When performed on 100 sick subjects, 99 flagged as positive
 - When performed on 100 healthy subjects, 99 flagged as negative
- You tested positive

Should you be worried?

It depends on the disease's ***rate of incidence***

- Assume a rate of incidence of 1/10000 (10^{-4})

Base Rate Fallacy – Example – Let's apply Bayes' Theorem

$$P(A|B) = \frac{P(B|A)P(A)}{P(B)}$$

- In our example: S sick, $\neg S$ healthy, T positive test, $\neg T$ negative test
- $P(T|S) = 0.99$, $P(\neg T, \neg S) = 0.99$, $P(S) = 10^{-4}$
-
- $P(S|T) = \frac{P(T|S)P(S)}{P(T)} = \frac{P(T|S)P(S)}{P(T|S)P(S) + P(T|\neg S)P(\neg S)} = \frac{0.99 * 10^{-4}}{0.99 * 10^{-4} + 0.01 * 0.9999} \approx 0.0098 \approx 1\%$

*So, you are probably fine,
given the rate of incidence and absence of other indicators*

Base Rate Fallacy – Back to IDSs

Most interactions on a system are from legitimate users

- Base rate plays an important role in IDS configuration
 - Too many alerts swarm the system, and users will start to ignore them
 - Too loose IDS will miss some real attacks

So, how do we decide?

- Threat modelling → Informed (yet imperfect) decision

Network Security

- Interesting Secure ***Protocols*** and ***Attacks*** per OSI Layer
 - IPSec
 - ICMP Redirect Attack
 - Smurf (and Fraggle) Attack
 - TCP Three Way Handshake and SYN Flooding
 - SSH
 - HTTPS
 - DNS Spoofing and DNS Poisoning
- Firewalls
 - Packet-filtering Firewalls
 - Proxy Firewalls
 - Tiered Architecture
- Intrusion Detection Systems
 - Event Analysis Methods
 - Base Rate Fallacy

Outlook

- We covered the basics of **Network Security**
- Next week we move to a new chapter, which aligns with your upcoming assignment: **Application Security**

Stay Tuned.....

Questions?



Universiteit
Leiden

Bij ons leer je de wereld kennen